

ELITE STAR MEDICAL CLINIC

Information Security Policy

Document ID:	ESMC -IS-001
Version:	1.0
Effective Date:	April 25, 2026
Last Reviewed:	April 25, 2026
Classification:	Internal – Confidential

1. Purpose and Scope

This Information Security Policy (ISP) establishes the framework for protecting the confidentiality, integrity, and availability (CIA) of all information assets owned, managed, or processed by Elite Star Medical Clinic. The policy applies to all workforce members, contractors, vendors, and business associates who access, process, store, or transmit clinic information systems or data.

This policy aligns with the HIPAA Security Rule (45 CFR Parts 160 and 164), the NIST Cybersecurity Framework (CSF), the HITECH Act, and applicable California state information-security regulations.

2. Role and Responsibilities

Chief Executive Officer (CEO):

Provides overall accountability for information security and ensures appropriate resources are allocated.

Privacy & Security Officer (PSO):

Develops, implements, and enforces this policy; conducts annual risk assessments; manages incident response; serves as the primary HIPAA compliance contact.

IT Administrator / IT Manager:

Implements and maintains technical security controls, access management, system patching, backup operations, and endpoint protection.

All Workforce Members:

Must read and comply with this policy, complete annual security-awareness training, safeguard clinic information, and report suspected incidents immediately.

Business Associates:

Must sign a Business Associate Agreement (BAA) and implement safeguards equivalent to those required for ePHI.

3. Access Control

3.1 Principle of Least Privilege

Access shall be granted only to the minimum level necessary for job duties. All access must be requested by the supervisor and approved by the PSO.

3.2 User Account Management

- Unique user accounts are required; shared accounts are prohibited.
- Accounts must be disabled within 24 hours of termination or role change.
- Privileged accounts must only be used for administrative functions.
- Multifactor authentication (MFA) is required for all remote access and all systems containing ePHI.

3.3 Password Requirements

- Minimum length: 12 characters including uppercase, lowercase, numbers, and symbols.
- Password reuse is prohibited for the last 12 password cycles.
- Passwords must be changed every 90 days or immediately upon suspected compromise.
- Password managers are recommended for secure credential storage.

4. Device and Endpoint Security

- All devices accessing clinic systems or ePHI must be enrolled in clinic device-management tools.
- Full-disk encryption is required on laptops, workstations, and mobile devices.
- Automatic screen lock must activate after 5 minutes of inactivity.
- Antivirus/EDR must be installed and updated on all endpoints.
- Operating systems and applications must be patched within 30 days of critical update release.
- Personal/BYOD devices require written PSO approval before accessing clinic data.

5. Network Security

- A next-generation firewall must be deployed at all network perimeters.
- The clinical network must be segmented from guest Wi-Fi and IoT/medical-device networks.
- Remote access must occur through an encrypted VPN with MFA.
- Wireless networks must use WPA3 encryption.
- Network activity must be monitored, logged, and retained for at least 6 years.

6. Data Classification and Handling

Restricted (PHI/ePHI):

Highest protection level. Access is strictly limited. Encryption is required at rest and in transit. Must not be transmitted via standard email without HIPAA-compliant encryption.

Confidential:

Internal business information is limited to authorized roles; external sharing requires PSO approval.

Internal:

Standard internal information not intended for the public.

Public:

Information approved for public release.

7. Encryption Standards

- ePHI must be encrypted at rest using AES-256.
- All data in transit must use TLS 1.2 or higher.
- PHI sent via email must use HIPAA-compliant encryption.
- Encryption keys must be stored separately, access-controlled, and rotated annually.

8. Security Incident Response

All suspected or confirmed security incidents must be reported immediately to the PSO.

The incident-response process includes:

Identify: Detect and verify the incident using monitoring tools, alerts, and user reports.

Contain: Limit damage by isolating affected systems.

Eradicate: Remove malicious code, eliminate unauthorized access, and patch vulnerabilities.

Recover: Restore systems and ensure they return to normal operation.

Notify: Notify affected individuals, HHS OCR, and law enforcement as required. The HIPAA

Breach: Notification rule requires notices within 60 days for large breaches.

Review: Conduct a post-incident analysis and update controls.

9. Breach Backup and Business Continuity

- Critical data must be backed up daily to an encrypted, geographically separate location.
- Full restoration tests must be conducted quarterly.
- Business Continuity (BCP) and Disaster Recovery Plans (DRP) must be maintained and tested annually.
- RTO: 4 hours for critical systems
- RPO: 24 hours

10. Acceptable Use

- Clinic systems must be used only for authorized business purposes.
- Unauthorized software installations are prohibited.
- Personal use must be minimal and must not affect security.
- Storing PHI on personal cloud storage (Dropbox, Google Drive, etc.) is prohibited.
- Workforce members must not share patient information or internal data on social media.

11. Vendor and Third-party Management

Vendors and business associates with system or PHI access must:

- Sign a BAA before any access is granted.
- Demonstrate adequate security controls via a vendor risk assessment.
- Undergo annual security review and reassessment.
- Notify the clinic within 24 hours of any breach or security incident involving clinic data.

12. Security Awareness Training

All workforce members must complete:

- Initial training within the first 30 days of hire
- Annual refresher training thereafter

Training must cover phishing, password hygiene, PHI handling, incident reporting, and social engineering. Records must be retained for 6 years.

13. Policy Enforcement & Sanction

Violations may result in:

- Loss of system access
- Written warnings
- Disciplinary action up to termination
- Contract termination for vendors
- Reporting to law enforcement or regulatory authorities if required

Sanctions will reflect the severity of the violation and harm caused.

14. Policy Review and Updates

This policy shall be reviewed annually, or sooner, following:

- Significant security incidents
- Regulatory or legal changes
- Major operational or technical changes

The PSO is responsible for ensuring timely updates.

Policy Approval

Name	Title	Signature/ Date
Chief Executive Office		
Privacy & Security Officer		